# AlphaQ


- Denistan B
- Danushika N
- Nivetha M
- Sakthi S

denistanb05@gmail.com
Kumaraguru College of Technology

# ZeroWatch: Agentic Continuous Identity Verification

T2PS1 | HackToFuture 4.0 | Team AlphaQ

Traditional auth (passwords, OTPs, SSO) verifies identity only at login — never again during the session. A stolen session token grants unrestricted access until expiry. In cloud-native microservice environments, compromised identities move laterally across services with zero resistance. Existing tools (Entra CAE, Darktrace, CyberArk) each solve one slice: CAE covers only Microsoft, Darktrace detects but cannot explain, CyberArk protects only privileged accounts, and every tool leaves new users unprotected for 14-30 days. Enterprises need continuous re-verification on every action — across every vendor — starting from day one.

# How ZeroWatch Works

**The Base — 3 things watched on every action, not just at login**

- ▶ **User Behaviour** How you type, move your mouse, and use the app — your personal rhythm.
- ▶ **Device Characteristics** A silent fingerprint of your GPU, screen, and browser. Unique to your machine.
- ▶ **Contextual Signals** Your location, network, and time of day. Flags when something is out of place.

**The Lock — DPoP device binding makes a stolen cookie useless**

- ▶ **Private key locked to your browser** Generated once using WebCrypto. It physically cannot be copied or extracted.
- ▶ **Every request is signed by it** Attacker steals the cookie but has no key → rejected on the very first request.

**The Decision — a live risk score 0 to 100, updated every 3 seconds**

- ✔ **0 to 30 — Allow** Zero friction. Real user, normal behaviour.
- ⚠ **31 to 70 — Step-up MFA** Something changed. Verify once more before continuing.
- ✖ **71 to 100 — Block and Report** Session terminated. Claude writes a plain-English incident report in 3 seconds.

# 5 Innovations Built on This Foundation

1. **Day-1 Baseline (LLM)** Claude creates your behavioural profile the moment you join. No 30-day blind window.
2. **Incident Narration (LLM)** Attack detected? Claude writes a plain-English report in 3 seconds — not a cryptic score.
3. **ECDSA Device Binding** DPoP applied to cookie sessions for the first time. Stolen token alone is useless.
4. **Predictive Trajectory** Score is projected forward. MFA fires before the attack completes, not after.
5. **Intent Classification (LLM)** Claude reads 10 API calls as a sequence. Catches slow, stealthy attacks others miss.

# Tech Stack

- **Signal Collection:** JS Browser SDK (keystroke/mouse/scroll) · FingerPrintJS Canvas+WebGL device hash · MaxMind GeoIP2 (IP, VPN/Tor, impossible travel) · WebCrypto ECDSA P-256 + IndexedDB
- **Stream Processing:** Apache Kafka (async signal queue, durable, decoupled) · Apache Flink (stateful per-session z-score, sub-100ms, 1M+ events/sec)
- **Risk Engine:** scikit-learn Isolation Forest (per-user anomaly baseline) · ONNX Runtime CPU inference sub-5ms — no GPU needed · Redis TTL cache sub-1ms lookup
- **LLM Layer:** Claude Sonnet (Anthropic API) — cold-start synthesis + incident narration + intent classification. Always async — never on hot request path.
- **Cross-Platform Enforcement:** Kong/NGINX Lua · AWS Lambda Authorizer · Azure APIM Policy · GCP Apigee · Istio EnvoyFilter (same YAML: AWS EKS / Azure AKS / GKE / on-prem k8s)
- **Infrastructure:** FastAPI (Python) · Kubernetes + Docker (HPA auto-scale) · SPIFFE/SPIRE · PostgreSQL + TimescaleDB · React dashboard (WebSocket live feed)
- **OS / Platform:** Windows + Linux + macOS — enforcement at API Gateway layer. No OS-specific code. Chrome, Firefox, Safari, Edge. Any cloud or bare metal.

# Implementation Plan

- **System Placement — Layer 5 (API Gateway + Service Mesh):** Universal chokepoint — every request passes here regardless of vendor. Enforces BEFORE business logic. Zero app code changes. Works for legacy apps, SaaS, microservices, AI agents.
- **Cross-Platform — 1 Redis, Multiple Plugins:** All gateway plugins (AWS/Azure/GCP/on-prem) read the same Redis risk score. Score propagates globally in sub-50ms. Token theft blocked on all platforms simultaneously.
- **Phase 1 — Signal Layer (6h):** JS SDK + FingerPrintJS + MaxMind + Kafka. ECDSA key pair in IndexedDB. Fetch interceptor signs every request automatically.
- **Phase 2 — Risk Engine (8h):** Flink + Isolation Forest baseline + z-score + ONNX export (sub-5ms CPU). Redis TTL cache. 3-tier routing: Tier1 edge sub-2ms, Tier2 async, Tier3 LLM under 1%.
- **Phase 3 — LLM Integration (6h):** Cold-start: Claude → JSON baseline at account creation. Incident: z-scores → Claude → plain-English in 3s. Intent: 10-call sequence → Claude → classification.
- **Phase 4 — Enforcement + Mesh (6h):** Gateway plugins + Istio EnvoyFilter injects X-ZeroWatch-Score. ECDSA middleware verifies signature vs Redis public key per request.
- **Phase 5 — Demo Build (6h):** React: live risk timeline + heatmap + incident panel. Demo: stolen token Russia → score 95 → terminated → Claude report 3s → AWS also blocked.

# System Architecture & Key Differentiators

- **Architecture — 4 Layers:** L1: Browser SDK → Kafka (0ms, async) · L2: Flink → Redis risk score · L3: API Gateway + Istio enforce on every request · L4: Claude API async (cold-start + narration + intent, under 1% of requests)
- **Why Layer 5 (API Gateway + Service Mesh)?** Vendor-agnostic universal chokepoint. Sees authenticated identity from JWT. Sits before execution. Programmable — no app code changes. Covers legacy apps, SaaS, microservices, AI agents simultaneously.
- **Computation — No GPU, Low Overhead:** Tier 1 edge sub-2ms (90% requests) · Tier 2 ONNX CPU sub-5ms async (9%) · Tier 3 LLM sub-200ms async (under 1%). Average: under 0.1ms overhead per request. ONNX runs on standard CPU.
- **Scalability:** Kafka+Flink: 1M+ events/sec · Kubernetes HPA: auto-scales under load · Redis cluster: HA · LLM: under 1,000 calls per million sessions · Stateless pods: horizontal scale
- **vs Microsoft Entra CAE:** CAE: 15s revocation, Microsoft-only, no behavioural signals, no explanation. ZeroWatch: sub-2ms, all vendors, full behavioural scoring, 3-second plain-English incident report, predictive pre-emption.
- **vs Darktrace / Securonix:** Both: anomaly detected → severity number → 45-min SOC investigation. ZeroWatch: detection + 3-second explanation + pre-emptive challenge. 200 alerts/week triaged in 40 min.
- **Unique (no competitor has all):** Day-1 LLM synthetic baseline · 3-second incident narration · ECDSA device binding for stateful sessions · Predictive risk trajectory · LLM intent classification of API sequences

# Why ZeroWatch Wins

- **Solves All 3 Documented Industry Gaps:** Cold-start blindness (days 1–30) + ecosystem lock-in (Microsoft-only CAE) + unexplained alerts (SOC overload). All confirmed open in 2025 CSA + ISACA + Wavestone research. No existing product closes even two.
- **Zero User Friction, Zero GPU:** Async SDK + ONNX CPU model = 0ms added latency on 99% of requests. Standard CPU only — no GPU needed. 3-tier design keeps LLM off the hot path entirely.
- **5 Genuinely Novel LLM Applications:** Cold-start synthesis · Incident narration · Intent classification · Predictive trajectory · Adversarial baseline probing. No SIEM, UEBA, IAM, or XDR tool uses LLM for any of these today.
- **ECDSA Device Binding — First for Stateful Sessions:** DPoP (RFC 9449, 2023) solved this for JWT. Nobody applied the equivalent to cookie sessions. ZeroWatch: stolen cookie + no device private key = blocked on first request. All browsers supported.
- **Standards-Aligned + Fully Open:** NIST SP 800-207 Zero Trust · DPoP RFC 9449 · FIDO2/WebAuthn principles · SPIFFE/SPIRE. No vendor lock-in. Bare metal, VMware, any cloud. Wavestone (Oct 2025) published the requirements — ZeroWatch is the implementation.
- **Demo — 5 Winning Moments:** (1) Day-1 user: LLM baseline active immediately · (2) Normal session: score 6, zero friction · (3) Stolen token Russia: score 95 live · (4) Claude report in 3 seconds · (5) AWS service blocked — Entra CAE cannot reach it.